
University of Portsmouth
BSc (Hons) Computer Science
Third Year

IT And Internetworking Security (ITINS)

M33141

January 2026 - June 2026

20 Credits

Thomas Boxall
`thomas.boxall11@myport.ac.uk`

Contents

1	Lecture - Introduction (2026-01-26)	2
2	Lecture - Threats, Risk Assessments & Trust (2026-02-10)	6
3	Lecture - Network Security (2026-02-17)	12
4	Lecture - Firewalls (2026-02-24)	16
5	Lecture - IDS & IPS (2026-03-03)	20
6	Lecture - AAA In Network Servers and Services (2026-03-17)	23
7	Lecture - IPSec, VPN & MPLS (2026-03-24)	29
8	Lecture - Auditing (2026-04-21)	36

Page 1

Lecture - Introduction

📅 2026-01-26

🕒 14:00

👤 Shikun

NB: This was split between 26th January and 2nd February lectures.

1.1 Introduction to Module

This module could alternatively be known as “Cyber Security for Enterprise and Infrastructure” however course leadership didn’t like the sound of it, so ITINS it is.

The module will be delivered through a mix of lectures and practical tutorials. The tutorials will use Cisco Packet Tracer to simulate networks, rather than use real hardware. There may be an option later in the module to visit the networking labs and see the real hardware. Worth noting that simulations are easier and quicker than completing the same activities on the real hardware.

There are a number of useful books for this module. The Cisco CCNA Security Guide (210-260) will be the main book for this module, and even the older versions are still relevant (and cheaper to acquire).

Assessments for the module will be worth 50% and will involve submitting 3 labs (2 to be selected from a list of 5) and a short report. The exam will be a mix of MCQ and longer form questions. The questions in the final exam will be from the CCNA. The final exam will be held during the May/June exam period and has previously fell towards the end of the time slot.

1.2 Introduction to Security

Computer Security is the idea of protection afforded to an information system in order to preserve the integrity, availability and confidentiality of information system resources. This covers hardware, software, firmware, information / data, and telecommunications.

Definitions

Threat A potential for violation of security

Vulnerability A way by which loss can happen

Attack An assault on system security, a deliberate attempt to evade security services

1.2.1 Impact of a Cyber Incident

A cyber incident is said to have a *low* impact if there is a limited adverse effect on organisational operations, assets or individuals. The loss may cause degradation in mission capabilities to an extent and duration that the organisation is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced. There may also be minor damage to organisational assets, minor financial loss or minor harm to individuals.

The impact is classified as *moderate* if there is a serious adverse effect on the operations of the organization, assets or individuals. There may be a significant degradation in the mission capabilities, duration and extent that the organisation is able to perform its primary functions but the effectiveness

of the functions is significantly reduced. It may result in significant damage to organisational assets, result in significant financial loss or result in significant harm to individuals that does not involve loss of life, or serious or life threatening injuries.

A *high* impact incident is classified as one which has a significant or catastrophic adverse effect on organisational operations, assets or individuals. The loss might cause a severe degradation in or loss of mission capability to an extent and duration that the organisation is not able to perform one or more of its primary functions. It may result in major damage to organisational assets, result in major financial loss or result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

1.2.2 Security Requirements

Different situations will prioritise different aspects of cyber security and therefore protecting assets differently. While all of the below examples all require strong security surrounding them, there is a security trait (confidentiality, integrity, availability, etc) which is considered to be the most important trait.

Student Grades are considered *confidential* as they should not be shared

Patient Information is considered for it's *integrity* to be the strongest

Authentication Services are considered to require *availability* as the strongest trait as so many other systems rely on them

Admission Tickets should be *authentic* to prevent people spoofing them

Stock Sell Order should have *non-repudiation* as it's strongest trait to ensure the order is maintained.

1.2.3 Challenges with Security

Naturally, given users are involved in the equation, there are challenges with security:

- Security isn't simple, it is easy to get it wrong
- All potential attacks must be considered
- Procedures used can seem counter-intuitive
- Often involves algorithms and secret information
- Engineers must decide where to deploy mechanisms
- There is a battle of wits between attacker / administrators
- Not perceived until it fails
- Requires regular monitoring
- Security is often considered as an after-thought
- Regarded as an impediment to using the system

1.2.4 Cloud and Virtual Networking Security

Within a Data Center, there is a need for elevated security. This may include, for example, on-prem security officers, fences and gates, continuous video surveillance, security breach alarms, electronic motion detectors, security traps, and biometric access and exit sensors.

Definitions

Hyperjacking Attackers hijack a VM controlling software to attack other devices

Instant On Activation Old VM is activated with out of date security policies

Antivirus Storm When all VMs attempt to download antivirus data file at the same time

1.3 Introduction to Hackers

Modern hackers will go by many titles including:

- Script Kiddies
- Vulnerability Brokers
- Hacktivists
- Cyber Criminals
- State-Sponsored Hackers

However, generally they will fall into one of three categories.

White Hat Hackers are those who hack ethically. They use their skills in an ethical way to identify and responsibly report vulnerabilities in a legal way.

Grey Hat Hackers are those who commit crimes, and do arguably unethical things - but not for personal gain or to cause damage. They sit in the grey area between White and Black hat hackers.

Black Hat Hackers are unethical criminals. They violate computers and network security for personal gain or for malicious reasons.

1.3.1 Tooling

The tooling used by hackers has also evolved. Back in the 1980s, the tools were more rudimentary, requiring more specialist knowledge to operate them. While more recently, the tools have become more sophisticated therefore requiring less technical knowledge to operate them.

Attack tools can be categorised into the following:

- Eavesdropping
- Data modification
- IP based spoofing
- Password-based
- Denial-of-Service
- Man-in-the-Middle
- Compromised Key
- Sniffer

1.4 Policy

Policy says what is not allowed. It might sometimes also say what is allowed with relation to computer system.

The secure mechanism to enforce policy, where the set of reachable states are entirely contained within the set of secure states with a buffer, is regarded as often unobtainable yet the cyber security professional's preference.

The precise mechanism to enforce policy, where the set of reachable states is entirely contained within the set of secure states with no buffer, is precise in that there is no additional security; this is what managers like to aim for.

However in reality, the board mechanism to enforce policy is where some of the set of reachable is within secure but the other half is dangling out of secure. This is the reality for many organisations.

Page 2

Lecture - Threats, Risk Assessments & Trust

📅 2026-02-10

🕒 14:00

👤 Shikun

2.1 Policies

Within Cyber Security, policies are used to unambiguously partition system states. They correctly capture security requirements for a given system, user or the organisation as a whole. This definition can be simplified to *a statement of what is and what is not allowed*.

All security policy and mechanisms for their enforcement sit on top of assumptions. The assumptions support the mechanisms for enforcement to work correctly. Some of these assumptions may be documented in the policy, however some may not be.

There may also be ‘grey areas’ in the policies, or where they are not as precise as needed. For example - if an imaginary bank’s policy states that bank officers are authorised to transfer money amongst account; and a bank officer moves £100,000 into their account - has the bank’s security policy been violated? The answer can be seen both ways for this - yes in that they shouldn’t be able to touch their own account, but also no - as this hasn’t been documented in the policy. This makes the ‘yes’ answer assumption based and someone else may see this differently.

Alternatively, if it is deemed that a website has to be available, however the security policy doesn’t mention availability - the definition of security isn’t appropriate.

2.2 Trust vs. Assurance

Definitions

Trust the assumption that a system or service is secure

Assurance the degree of confidence that a system or service meets its security requirements

Trust is considerably more subjective than assurance. Trust is founded in beliefs, expectations, perceptions and subjective opinions often of those who shout the loudest. While assurance is based in evidence, standards, metrics and criteria - it’s a quantitative way of saying “yes, this is a secure system.”

Assurance is a measure of how well the system meets its requirements. It doesn’t say what the system is to do, rather it only covers how well the system does it. Assurance proves confidence; helps to identify and address any gaps or weaknesses; provides evidence and assurance to stakeholders, customers, regulators and auditors; and enables continuous improvement of the service.

In traditional industries - drugs are considered trustworthy based on a few factors:

- Certification
- Manufacturing standards

- Preventative sealing in packages

In cyber industries, data and services are considered trustworthy based on:

- Testing
- Auditing
- Monitoring
- Evaluating both effectiveness and performance

2.3 Analysis

Businesses are presented the question “Is it cheaper to prevent x from happening, or recover if x happens?”

This isn’t an easy question to answer - especially when x could be a major cyber incident stopping all business activities for n time; loss of earnings and loss of padding in the CEO’s back pocket... However, what if x doesn’t happen and never comes close to happening - that’s just a waste of money on preventative measures surely.

Cost-Benefit analysis is the solution to this - it is a data driven process used to evaluate the strengths and weakness of the options.

Part of CBA is Risk Analysis, which asks if the thing should even be protected in the first place, and how much should we protect this thing.

Risk analysis can be seen in a simple of example of what is the loss if a mobile phone gets stolen. Obviously there is the loss of service, and the loss of the physical asset - but what about the other dangers? What about the bank cards connected to Google Pay (or Apple pay for *those* weirdos)? When phrasing it like that - cyber cover for a mobile phone while still extortionately expensive, doesn’t feel like such a bad deal...

2.4 Humans Are Insecure

The systems we use are only as secure as the humans driving them. It would be great to have an IT system which users can’t get within 10’ of - so secure, but also just a bit useless as no one can do anything with it. A “secure” system can be breached by improper operation (for example when accounts with no passwords are created).

Within organisations, there is a need for there to be a match between those who have the power and those who have the responsibility for cyber security. For example, those who are responsible for security have the power to enforce security, otherwise there is confusion. However, when system administrators are responsible for implementing security officers can make the rules, there is power given without responsibility.

Data (from somewhere) shows that 80-90% of all security problems initiate from “insiders.” This is the situation where an account (either with the account holders’ knowledge or not) that already exists in the system is used in an unauthorised way. The remaining 10-20% of attacks come from outside the organisation, most commonly seen in the form of DDoS attacks.

It’s not just internal roles (Management, IT staff, Custodians, Ops Staff, Compliance officers, etc) who are risks in the system here - external (vendors, suppliers, contractors, temporary employees, etc) also provide risk. Often higher than that of internal staff as less internal vetting may have been conducted when taking on a new contractor. In this equation - HR are often the linchpin, as they are responsible for the hiring, termination and employee training.

Definitions

Masquerader A person who is not authorised to use a computer, but gains access appearing to be someone with authorisation

Misfeaseor A person who has limited authorisation to use a computer, but misuses that authorisation

Clandestine User A person who seizes supervisory control of a computer and proceeds to evade auditing and access controls

Hacker Generic term for someone who does unauthorised things with other people's computers

2.5 Risk

Risk is *the likelihood that something bad will happen that causes harm to an informational asset (or the loss of the asset)*.

A vulnerability is a weakness that could be used to endanger or cause harm to an informational asset. A threat is anything (man made or act of nature) that has the potential to cause harm. The likelihood that a threat will use a vulnerability to cause harm creates a risk.

The impact of a risk happening is the loss of availability, integrity, and confidentiality; as well as possible other business losses such as lost income, loss of life and loss of real property.

It is not possible to identify all risks nor to eliminate all risks. However we can use a risk assessment to do some of this for us.

2.5.1 Risk Assessment

A risk assessment is a systematic and comprehensive analysis of the probability of a certain event occurring and the potential consequences that might result from that event. It is used to identify and characterise risks.

Risk assessments, while dense paperwork, can help to improve security and may even increase productivity. They can also reduce costs. They work in a four step process:

1. Identify risks
2. Analyse the likelihood of those risks
3. Formulate solutions for reducing risks
4. Continuously monitor risks

There are lots of different types of risk assessment:

- Business impact assessment
- Qualitative risk assessment
- Quantitative risk assessment
- Cost-Benefit analysis
- Probability profile analysis
- Failure modes, effective and criticality analysis

There are a number of formal Cyber Security risk frameworks which can be used to identify and respond to risks in:

- NIST Cyber Security Framework
- ISO 27005
- FAIR (Factor Analysis of Information Risks)

A risk assessment might identify risks such as

- Ransomware
- Data leaks
- Phishing
- Malware
- Insider Threats
- Denial of Service
- Unauthorised access
- Misuse of information by authorised users
- Weaknesses in organisational security controls
- Data leaks and breaches
- Service disruption

A risk assessment is carried out by a team of people who have knowledge of specific areas of the business. Membership of the team may vary over time as different parts of the business are assessed. The assessment may use a subjective qualitative analysis based on informed opinion, or where reliable monetary figures and historical information is available - the analysis might use quantitative analysis.

For a given risk, Management can choose to accept the risk based on one of three options (or some combination):

- the relative low value of the asset
- the relative low frequency of occurrence
- the relative low impact on the business

However, management might choose to release the proverbial purse strings and relinquish some cash to mitigate the risk. They'll select and implement the appropriate control measures to reduce the risk. In some cases the risk can be transferred (banished) to another business by buying insurance or out-sourcing the risk inducing activity to another business.

2.5.2 Risk Management

A key part of risk management is to identify the assets and estimated values, including the people, buildings, hardware, software, and data supplies. Then a threat assessment is conducted which includes acts of nature, accidents and malicious acts originating from inside or outside the organisation. A vulnerability assessment is also conducted, where for each vulnerability - the probability it will be exploited is calculated through evaluating policies, procedures, standards, training, and physical security.

This data is then used either in a qualitative or quantitative way to calculate the impact each threat would have on each asset. From which the appropriate controls can be identified and implemented. This process has to consider the productivity, cost effectiveness and value of the asset.

The Single Loss Expectancy (SLE) is a value which is calculated by multiplying the Asset's Value by the Exposure Factor (as a percentage of the assets value). The SLE can then be multiplied by the Annual Rate of Occurrence (ARO) which is the number of times per year that an incident is likely to occur to find the Annual Loss Expectancy (ALE).

2.6 Trusted Systems

A Trusted System is a platform designed to reliably enforce a specific security policy, ensuring it functions as intended without unauthorised modifications. Access is granted through an access right - which is a way in which an object can be accessed by a subject; typically this is granted as 'read', 'write' and 'execute'.

2.7 Formal Evaluation

Formal Evaluation is a method to achieve *trust*. It is not a guarantee of security. These methods are formal, which doesn't mean auditors in smart suits and little bow ties - it means the results have been found using the *language of mathematics*, logic and proof. The formal outcome should be able to be verified.

The formal evaluation process looks at the security requirements; if the assurance requirements showing how to establish the security requirements have been met; what the procedures to demonstrate the system meets the requirements look like; and outputs some metrics for the results. The products passing a formal evaluation are trusted, and often some level of formal evaluation will be required for an organisation to do business with another organisation.

Due to the complex requirements, it is often not feasible to formally verify an entire system. However discreet components are often verified.

There are a number of different specifications for formal evaluation, the first and most well known being produced by the US Department of Defence, called the *Trusted Computer System Evaluation Criteria* (TCSEC) but colloquially known (and feared) as the *Orange Book*.

2.7.1 TCSEC

The TCSES emphasises confidentiality. It has seven levels: D, C1, C2, B1, B2, B3, A1 where D is failed and A1 is perfect.

- C1 (discretionary protection) ensures appropriate identification and authentication are in place within the system, as well as discretionary access control is implemented.
- C2 (controlled access protection) validates that object reuse and auditing is appropriately configured.
- B1 (labelled security protection) mandates access control on a limited set of objects. It looks for an informal model of the security policy.
- B2 (structured protections) ensure that there is a trusted path for login; the principle of least privilege is followed; that there is a formal model of security policy; covert channel analysis is followed; and that there is configuration management throughout the estate.
- B3 (security domains) look for a full reference validation mechanism at the system architecture level; expects there to be constraints on the code development process; and looks for documentation and testing requirements.
- A1 (verified protection) demands formal methods for analysis and verification as well as trusted distribution.

2.7.2 ITSEC

ITSEC is the European answer to TCSEC. It came along a few years after the TCSEC and it's levels are considerably more hand-wavey.

- E1: Security target defined and tested; must have informal architecture description

- E2: Informal description of design; configuration control and code distribution
- E3: Correspondence between code and security target
- E4: Formal model of security policy; structured approach to design; design level vulnerability analysis
- E5: Correspondence between design and code; source code vulnerability analysis
- E6: Formal methods for architecture; formal mapping of design to security policy; mapping of executable to source code

2.7.3 Common Criteria

Eventually, US, UK, France, Canada and the Netherlands came together to produce the *Common Criteria for Information Technology Security Evaluation* (CCITSE or CC). Under the CC, each level of trust rating from the TCSEC can be specified as a protection profile (PP). A PP looks very similar to a level of trust rating but has two fundamental differences:

- the TCSEC binds sets of features and assurances together - the CC allows PP to combine features and assurances together in any combination
- the TCSEC specifies a fixed set of ratings (profiles) but the CC allows for consumers to write a customised set of requirements in a standard format

The CC is split into functional requirements (362 page document) which is divided into 11 classes with multiple families per class; and assurance requirements (216 page document) which is divided into 10 classes, with several families per class.

There are over 2200 registered products with the CC, which maintains an online portal of registered products.

Page 3

Lecture - Network Security

📅 2026-02-17

🕒 14:00

👤 Shikun

The University is writing some new AI guidelines which will be published in the coming weeks. We can still use AI to generate answers for the blue box tasks (practical tasks) in the Coursework regardless of the new guidance. Using AI for the red box tasks (theoretical tasks) depends on what the new guidelines say. Shikun will be in contact when he has received the new guidelines to mark the line in the sand for us.

3.1 Introduction

Network Security is the bulk of this module. Network Security is a set of technologies, policies and practices designed to protect the integrity, confidentiality, and accessibility of computer networks and data. It protects against malicious programs, actions and actors through a variety of mechanisms.

3.2 Malicious Software

Malicious Software can be categorised into one of two categories. It will either need a host program, such as trapdoors, logic bombs, trojan horses or viruses; or run independently such as bacteria or worms.

There are a number of things to look out for to identify if a machine has been compromised with malicious software:

- Computer running slowly, or using more resources than normal
- Audible noises, such as a churning drive, or features appearing which user hasn't installed
- Emails sent without users knowledge
- Duplicate services or unknown services appear and run on the system
- New directories or files appear, or old ones appear changed
- Mouse pointer moves unexpectedly or windows open by themselves
- Antivirus software, firewall, or other security products shut down

Spyware is a different type of malicious software which is designed to spy on the users activity, reporting back to a command and control server. There are a number of things which can suggest to a user that their PC may be compromised with Spyware:

- Web browser opens, after PC has been idle for some time, displaying website ads
- When websites are viewed, other browser windows open and display website ads
- Internet homepage unexpectedly changes
- Web pages are unexpectedly added to Bookmarks bar
- New toolbars are unexpectedly added to web browsers
- Programs cannot be started

- When links are clicked in a program, the link doesn't work
- If a browser suddenly closes or stops responding
- It takes a long time to start using the PC or to resume using the PC
- Program components no longer work

3.3 Network Security Architecture

There are four key components of the architecture of network security: wired components, wireless components, security domains and Virtual Private Networks (VPN).

The Internet is a network of networks. Each sub-network (a LAN, MAN, or small WAN) is connected by routers - there is no central command centre for the internet. The different sub-networks connect together using a common set of protocols.

The Transmission Control Protocol / Internet Protocol (TCP/IP) stack are two-level packages of protocols of transmission across the internet. They follow similar principles to the seven-layer OSI model but are much simpler. TCP is responsible for sequencing of series of packets to transmit data reliably over the internet; while IP flexibly routes information from source to destination.

TCP is not the only protocol which runs on top of IP. The Universal Datagram Protocol (UDP) is used for one-directional bursts of data, such as video files where a missing packet or two isn't the end of the world. Internet Control Messaging Protocol (ICMP) is used for network management; the *ping* command uses ICMP. The Unequal Cost Multicast Protocol (UCMP) is a multicast management protocol used for managing multicast groups for multicast transmissions.

The IP allows for a packet-switched paradigm to be used. This works by breaking the flow of information into chunks which is then routed independently by the best route to the destination. At the receiving end, the destination device must reassemble the packets into the correct order before passing back up the protocol stack to the application. Missing packets are handled by retransmission.

A packet will have a header which contains a number of information cells for data items such as the source and destination IP addresses, checksums, type of service, length and time to live. The time to live is the time for which that packet can be active on the network. It might be a number of hops between different routers or it might be an actual time. This can be used to prevent playback attacks.

The devices which route packets through the network are known as routers. They know of a number of routes which they learn through routing protocols such as RIP, OSPF or BGP. These use different metrics to determine the best route for the packets to take looking at the 'cost' which may be the speed of the link, the load of the link, the distance, the number of hops, etc.

There are, however, some issues with this setup. Principally, the client is trusted to embed the correct IP address of the destination (which they may have obtained through DNS). It is easy to override this using raw sockets. IP addresses can easily be overridden by anyone with IT knowledge to make it appear that a packet has come from an arbitrary source IP, which also means the responses will be sent back to the arbitrary source IP. This means it is more possible to launch anonymous denial or service attacks, or anonymous infection attacks (such as the slammer worm).

At layers 2 and 3 of the TCP model network packets pass by untrusted hosts. This can allow for eavesdropping (packet sniffing), especially when the attacker controls a machine close to a the victim (such as WiFi routers). The TCP state can be easily obtained by eavesdropping, which enables spoofing and session hijacking. TCP layers 2 and 3 are also vulnerable to DoS attacks.

3.4 Alice, Bob, & Trudy

The *Alice, Bob, and Trudy* model is commonly used in Cyber Security to represent a sender, receiver and adversary (of some flavour). Alice and Bob are secure sender and receivers (respectively) while Trudy is an adversary who has tapped the communication channel between Alice and Bob in a hope to either Hoover up data packets or inject her own.

Alice and Bob could represent web browsers / servers for electronic transactions (such as online purchases), on-line banking in the client-server paradigm, DNS Servers, routers exchanging routing table updates, etc.

Trudy, on the other hand, is up to many things including:

- Eavesdropping - intercept messages actively or insert messages into connection
- Impersonation - faking (spoofing) source address in packet (or any field in packet) to make it seem like she's not the sender
- Hijacking - taking over an ongoing connection by removing sender or receiver, inserting herself in place
- Denial of Service - preventing service from being used by others (e.g. by overloading resources)

3.5 Attacks & Countermeasures

There are a number of different types of attacks which have countermeasures.

3.5.1 Mapping

Before any attacking can take place, we have to first understand the estate we are trying to attack. This is similar to a burglar walking around a neighbourhood before attacking to see peoples patterns of movement etc, except in networking - we are looking for what services are implemented on the network. We can use *ping* to determine what hosts have addresses on the network or Port Scanning which tries to establish a TCP connection to each port in sequence and sees what happens. A common tool used for port scanning is *nmap* which was used in the Ethical Hacking module at L5.

There isn't much we can do to stop mapping. We can record all traffic entering the network and seek out suspicious activity (IP addresses, ports being scanned sequentially, etc) but as we know it's easy to spoof IPs so blocking one isn't going to necessarily stop an attacker.

3.5.2 Packet Sniffing

Packet Sniffing is the idea where one NIC can read all the packets passing for any broadcast traffic. A NIC is supposed to drop packets broadcast where it is not the intended recipient, so this shouldn't be an issue except for when the NIC is setup to be malicious.

There are a few countermeasures to sniffing - such as all hosts in an organisation running software that checks regularly if host interfaces are in loose mode; or configuring the network such that there is one host per segment of broadcast media (switched Ethernet as hub).

3.5.3 IP Spoofing

It's possible for a device to generate 'raw' IP packets directly, putting any value into the source IP address field. The receiver cannot tell if the source IP has been spoofed or not.

Countermeasures wise, routers should be configured to not forward outgoing packets with invalid source addresses (e.g. datagram source address not in the routers network).

3.5.4 Denial of Service (DoS)

DoS attacks are where a receiver is swamped by a flood of maliciously generated packets. In a simple DoS attack - they would all come from the same host, or same network, so it is simpler to block one IP or a range to prevent the attack.

There is a variant of DoS attacks known as Distributed Denial of Service (DDoS) attacks in which multiple hosts are used to send malicious packets, so it becomes harder to filter these out and block them.

For both types of attack - the best countermeasure is to trace back to the source of the floods and identify if that machine has been compromised if so remediate or otherwise block.

3.5.5 Network Redirection

Network Redirection is an attack type in which intruders can fool routers into sending traffic to unauthorised locations.

The countermeasures are simple here - routers should only listen to approved information sources. However, many sites cannot afford to sacrifice flexibility like this so there is a need for a compromise to be reached.

3.5.6 Cross-Site Scripting

Cross Site Scripting (XSS) is where an intruder sends the victim a link to the trusted site with malicious code embedded.

The countermeasures to this are focused around the users, where they need to be informed to inspect URLs before clicking on them as it is not always possible to identify and block XSS attacks in the email filtering level.

3.6 Defences for Attacks

There are a number of defences for attacks. The data flow can be used to identify anomalous patterns which may indicate an attack is taking place. Access rights for individuals should also be monitored and managed to ensure they are appropriate for the individuals current role. Sandboxing can be used as a safe way to explore risky links, or risky applications - allowing Cyber Security professionals to test in a safe way.

3.7 Network Security

There are lots of security protocols used in network security, which include:

- Secure Socket Layer / Transport Layer Security (SSL/TLS) - mainly used to secure web traffic
- Secure SHell (SSH) - remote login
- IPsec - IP-level security suite

Wireless connections can be protected using 802.11i / WPA2, wired connections can be protected using IPSEC. The perimeter of a network can be defended using a firewall or Intrusion detection. Network infrastructure can be protected using BGP and S-BGP as well as DNS rebinding and DNSSEC.

Page 4

Lecture - Firewalls

📅 2026-02-24

🕒 14:00

👤 Shikun

Within networking, there are often three “zones” seen and discussed.

Definitions

Internet Outside the network we are thinking about, full of evil stuff.

Demilitarized Zone (DMZ) Services which sit ‘within’ the network, but need some direct exposure to the outside internet and internal access. Often includes services such as mail forwarding, Web Server, DNS servers, etc.

Intranet Entirely within the network, no outside-originating network traffic can access, only people internal to the organisation can access this.

Between the boundaries of network segments, there is a need for control over what traffic can get through and what traffic cannot get through. For example, to maintain security in the Intranet - we need to ensure that no outside originating traffic has access; or for the DMZ that only specific traffic can access specific services within it.

The answer to this need is a *firewall*. A firewall separates two networks, so is in essence a router, and is often deployed to separate the local area network from the internet - therefore all packets between the LAN and the internet are routed through the firewall.

The name ‘firewall’ comes from the traditional terraced house. In a terraced row, a ‘firewall’ would be erected between each individual house to prevent the spread of fire, prevent intrusion, and stop noise leaking from one property to another. The Cyber Security firewall we’re discussing is similar to this, in that it sits between adjoining properties (networks) but it only selectively blocks rather than blocking everything.

Firewalls focus on confidentiality and availability, they let legitimate traffic through while blocking suspicious / actually malicious packets. Firewalls can be placed at layer 2 or 3 of the OSI model or within the application layer.

Firewalls operate in one of two modes. The most common mode is “block by default, allow some” which is where the network administrator has to add explicit allow rules to the ruleset for all the traffic they want to allow on their network. The less common, and significantly less secure mode, is “allow by default, block some” which is the inverse of the previous method - where the firewall allows everything by default and the network administrator has to block everything they do not want coming into the network; this obviously leaves a much larger chance for incorrectly configured rules leaving a backdoor into the network.

4.1 Basic Packet Filtering

At their core, firewalls work through filtering the packets using transport layer information only. This is looking at attributes such as the following:

- Source IP Address or Destination IP Address

- Protocol (i.e. TCP, UDP, ICMP, etc)
- TCP or UDP source & destination ports
- TCP Flags (SYN, ACK, FIN, RST, PSH, etc)
- ICMP Message Type

The port number used is quite a common way of filtering packets. Specific applications will use a specific port for their communications. Within TCP connections - servers use port numbers less than 1024 and clients use port numbers between 1024 and 16383 (the highest possible number). Ports less than 1024 are permanently assigned, some examples below:

- | | |
|--------------------------------|------------------------------------|
| • 20 and 21 for FTP | • 80 for HTTP |
| • 22 for SSH | • 110 for POP3 (collecting emails) |
| • 23 for Telnet | • 143 for IMAP (collecting emails) |
| • 25 for SMTP (sending emails) | • 443 for HTTPS |
| • 52 for DNS | |

As the port number grows to 1024 and above, they are not statically assigned. These are used for the client to make connections. Within stateless packet filtering - this is a disadvantage as if the client wants port 2048 the firewall must allow incoming traffic on that port; however it is better in stateful filtering as it can be set to only allow incoming traffic on high port to a machine that has initiated a request to a machine on a low port.

4.2 Proxying Firewalls

A Proxying Firewall works at the application layer to inspect traffic hitting the application and preventing direct connections between internal clients and external servers. It masks internal IP addresses and blocks malicious content before it reaches the network.

The proxies can be tailored to specific protocols, for example HTTP, FTP, SMTP, etc; with some protocols easier to proxy than others. This is a flexible approach to firewalls, however it does introduce some delays with the packets being inspected and then reconstructed. “Batch” based protocols are natural to proxy, such as SMTP, NNTP, DNS or NTP.

Their core function is to protect the host running the required protocol stack. To aid this, all other services which are not needed should be disabled and security audits should be run to establish the baseline security of the system. Administrators should generally be prepared for the system to be compromised.

Web traffic (HTTP or HTTPS) can be scanned. This can be intercepted and proxied, which is usually host-based and done at enterprise gateways. Known bad sites can be blocked, along with those with known attacks. Attachments can be scanned to look for threats such as viruses, worms and malware.

4.3 Type of Firewall

There are four key different types of firewall.

4.3.1 Packet Filter

Rules defined on the firewall specify which packets are allowed in through the firewall and which are dropped. Rules must be configured to allow for packets to pass in both directions. Rules may specify source / destination IP addresses as well as source / destination TCP / UDP port numbers. Certain

(common) protocols are very difficult to support securely (e.g. FTP). They provide a low level of security.

4.3.2 Circuit Level Proxy

This is similar to a packet filter except that packets are not routed by the proxy. The proxy accepts incoming TCP/IP packets and uses rules to determine which connections will be allowed and which will be blocked. The connections which it has allowed generate new connections from the firewall to the server. The rules are specified in a similar way to a packet filter. It provides a low-to-medium level of security.

4.3.3 Stateful Packet Filter

This is a packet filter which understands requests and replies - such as TCP SYN, SYN-ACK and ACK. The rules only need to specify packet sin one direction (from client to server) as in the first packet in the connection with the subsequent replies and further packets in the communication being automatically processed. Stateful packet filters support a wider range of protocols than simple packet filters, such as FTP, IRC, H323. They provide a medium-to-high level of security.

4.3.4 Application Level Proxy

This provides a complete client & server implementation in one box for every protocol which can be expected to pass through it. It works by the client connecting to the firewall which validates the request. The firewall then connects to the server. The response comes back through the firewall and is also processed through the client/server. This uses a large amount of processing per connection. It provides a high level of security.

4.3.5 Bonus Fifth Classification

There is a fifth category of firewall - 'Personal Firewalls.' These are applications which run on end-users personal computers. They are most often of the packet filter type, sometimes stateful. They automatically configure themselves, for the most part, learning which applications are permitted to make which type of connections outbound. Generally they will block inbound access unless it is a reply.

4.4 Why Do We Need Firewalls?

Firewalls control network traffic to and from the protected network. They can allow / block access to services (both internal and external) as well as enforcing authentication before allowing access to services. Firewalls monitor traffic in & out of the network.

Firewalls are deployed to defend a protected network against an attacker which tries to access vulnerable services which should not be available from outside the network. For example a Microsoft Exchange server running SMTP probably shouldn't be able to be accessed using HTTP, FTP or SMB; alternatively a Linux Web or Mail server shouldn't be able to be accessed using Telnet or rlogin.

Firewalls also provide the ability to restrict internal access to internal services. Sometimes this would be for security reasons - not waning people to download and install unknown applications, or for productivity reasons - not wanting people wasting time on non-work related websites. They may also be cost related, such as not wanting to pay the ISP for large amounts of data transfer where it may not all be necessary.

4.5 Limitations of Firewalls

Firewalls do not do content-based filtering of packets. This means that if emails are allowed through, then emails containing viruses are also allowed through; or if web access is permitted, indecent websites are permitted, etc.

This lack of content filtering extends to application-proxy firewalls. There is an increasing number of services being offered across the internet using TCP port 80 (HTTP) which are no longer just web pages. This makes it increasingly difficult for firewalls to simply allow or block access to different services based on port and protocol.

Firewalls can most certainly not examine any form of encrypted traffic such as HTTPS or SSH. This is becoming a more widespread problem as encrypted network traffic is everywhere. These encryption systems (such as SSH or TLS) are end-to-end encrypted and designed as such that no system in the middle can decode the data.

It is possible to bypass firewalls. For example through directly connecting to the outside network rather than the intranet. Alternatively through poor configuration - such as allowing access to any machine inside or outside the network on TCP/UDP port 53; or through misconfiguration with in-bound/out-bound filtering where inbound traffic may be blocked but outbound initiated links work both ways.

Firewalls are susceptible to IP Spoofing - where they don't have a way of telling if the data really claimed from the same source. They also do not handle multiple applications which require special treatment very well, where each application might have it's own gateway. Client software must also know how to contact the gateway, for example through setting the IP of the proxy in the web browsers.

There is always a trade-off with Firewalls - what is the right balance of allowed communication with the outside world vs what level of security is needed. Many highly protected sites still suffer from attacks.

4.6 Real-World Firewalls

Firewalls take a number of different form factors. Enterprise firewalls will often come as rack-mountable units so they can be put in comms racks, but there's nothing stopping them being a small box which has to be put on a shelf in a rack.

Firewalls can be deployed in a of different scenarios. The Cisco ASA can be deployed in two modes:

- Routed mode - where it sits on the border between two networks acting as a Layer 3 NAT boundary.
- Transparent mode (bump in the wire or stealth firewall) - where it operates inline to the rest of the network, i.e. there are two routers and the firewall is between them. The firewall is not a NAT boundary, therefore the existing IP addresses cannot be altered.

There are three deployment scenarios Cisco uses for the ASA 5505 firewall:

- Small branch - where the firewall sits in the centre of a 'branch office' where there two VLANs - Outside & Inside, all internal devices within the Inside VLAN.
- Small Business - where the firewall sits in the centre of a 'small business office' where there are now three VLANs - Outside (internet only), Inside (end user workstations & phones), and DMZ where a web server resides.
- Enterprise - where there is a corporate headquarters connecting to two Telecommuter each over an IPsec VPN (more on this in a later week) with both the headquarters and telecommuters having an ASA Firewall at the boundary between them and the Internet.

Page 5

Lecture - IDS & IPS

📅 2026-03-03

🕒 14:00

👤 Shikun

5.1 Network Intrusion

Before we can look at what IDS and IPS are - we must first appreciate the steps for network intrusion.

5.1.1 Step 1: Reconnaissance

The first step looks at finding out information about the network. Often this is done through scanning the network to locate which IP addresses are in use, which operating systems are used and what TCP or UDP ports are 'open' (meaning they are being listened to by servers). This finds the way into the network, for us to use at a later step.

5.1.2 Step 2: Access

Now we have identified our 'way into' the network, we can run exploit scripts against them and see what works. These scripts insert malicious code, generally at the operating system or shell level. They often try a number of commands until one succeeds, such as trying to change passwords for users, open easier back doors, etc. The goal of this step is to become an insider.

5.1.3 Step 3: Elevate

Now we're in and we have some credentials - our next goal is to acquire root / system administrator privileges. There are lots of different methods which can be used here, although none divulged during the lecture (something to do with it being problematic for us to know this...).

5.1.4 Step 4: Root Kit

The elevated privileges we've just acquired are all well and good, but they're probably an existing admin account - so that's likely to be flagged so it's a matter of [seconds/minutes/days/hours/weeks/months] until we get locked out, depending on how effective the Cyber Security team are. So our next step is to install a permanent back door, called a root kit, which allows us to access the system as and when we want to. Hackers will also remove any audit log trails which have been created so far - as to reduce the chance of being noticed by system administrators.

5.1.5 Step 5: Utilise

We're in, we have our backdoor, and we haven't been noticed by the system administrators yet. The next step of network intrusion is to utilise this access for bad things. Often this is done through the intruder inviting additional intruders to exploit the access for activities such as ID theft or releasing a botnet. More hackers utilising the access has the added benefit of making it harder to trace individuals due to sheer numbers of them.

5.1.6 Detect & Overcome

System administrators would be able to detect port scanning with ease. This is noticeable behaviour - sequentially scanning through all ports in reasonably quick succession. The normal, expected, behaviour here is to directly connect to the one port that you need access to.

Two logins from the same user within a short amount of time is also suspicious - it could suggest a compromised account failing to do something, so then having to go all the way out and back in again, or just an actual administrator doing something then rebooting the server and logging back in to it.

It is impossible for an administrator, or team of administrators to monitor all the requisite logs to identify the issues alone - rather they should utilise tooling (no, not grinders, drills, or spanners - technical tools) to recognise and mitigate threats.

5.2 IDS & IPS

Intrusion Detection System (IDS) is the first generation of tooling that monitors network traffic and system activities for malicious actions, policy violations, or suspicious behaviour. Importantly, IDS only observes - it does not take any action.

Intrusion Prevention System (IPS) is the second generation of tooling which performs all the functions of IDS but is also able to action on the malicious traffic, i.e. re-routing it to a honeypot or blocking it altogether. IPS came about because engineers discovered that if they put the IDS module in a different place within the network - it would also be able to block the traffic, rather than just alert.

IDS and IPS both use signatures to detect typical intrusive activities. This method is called misuse detection - where the signatures are playbooks of known attacks looking at their network connections. If a network connection is seen which matches that of a known attack - the IDS will report that the misuse has happened. This is similar to the way that Anti-Virus applications work, where they look for known behaviours / changes made to operating systems and detect issues based on this. The signatures are bundled into an update to the IPS which comes from the vendor (or a third party which the vendor contracts). Signatures have a clear criteria for activation - being either atomic (only requiring one packet) or composite (requiring many packets to trigger).

IDS and IPS can also use anomaly detection. This is where the events taking place on the network are fed into a calculation engine, which also knows some information about unusual words or symptoms, which uses equations / algorithms to generate a score. Depending on what this score is - will decide if the administrator is notified or not. It will mostly generate false alarms.

IDS is deployed in a network everywhere that traffic might go from one layer to another. In a large, enterprise network, there would most likely be a centralised IDS reporting & management server which manages the individual IDS nodes. IPS can be deployed as 'Network Based IPS' where it is in-line at the border between different networks.

IDS and IPS complement each other. Both can be setup in the same network at the same time, they are not mutually exclusive. If the organisation is able to afford two - the IPS should be deployed in-line at the entry point to the network, and the IDS should be in passive mode; however if the organisation can only afford one - this should be an IPS which is deployed in inline mode.

IPS in inline mode does come with some risks, however, in that it introduces a delay in the network while the traffic is examined as well as a failure / overload of the IPS sensor would impact on the network as a whole. IDS in passive mode does not have the same risks however it cannot action responses to malicious packets as well as the fact that it is more vulnerable to evasion tactics.



There are some more specifics of Signature Micro Engines and actions taken by signature detection in the slides available on Moodle. These weren't discussed or referenced in the Lecture - so haven't been included here.

Page 6

Lecture - AAA In Network Servers and Services

📅 2026-03-17

🕒 14:00

👤 Shikun

6.1 Introduction to AAA

AAA stands for *Authentication, Authorisation, and Accounting*.

Definitions

Authentication The process of verifying the digital identity of an entity (is the entity who the entity says the entity is)

Authorisation Determines who the entity is and what level of access the entity should have (does the entity need basic user access or admin level access)

Accounting Keeps track of what the entities did while using the system

The idea of AAA can be translated to a Credit Card. In that the Authentication is the credit card number; the authorisation is the limit applied to the card; and the accounting is the statement.

6.1.1 Authentication

There are two *Authentication Modes*:

- Local AAA Authentication
- Server-Based AAA Authentication

6.1.1.1 Local AAA Authentication

In this paradigm, the remote client communicates directly with an AAA Router. The AAA router connects to the wider network.

1. The client establishes a connection with the router
2. The AAA router prompts the user for a username and password
3. The router authenticates the username and password using the local database and the user is authorised to access the network based on information in the local database

This paradigm is most commonly seen in one-to-one devices such as personal computers or mobile phones.

6.1.1.2 Server-Based AAA Authentication

In this paradigm, the remote client communicates with an AAA Router who authenticates against an ACS Server (Cisco Secure ACS Server to be precise).

1. The client establishes a connection with the router

2. The AAA router prompts the user for a username and password
3. The router authenticates the username and password using a remote AAA server
4. The user is authorised to access the network based on information on the remote AAA server

This paradigm does not use the local authentication daemon on the AAA router, rather it passes the request to a third party server to complete the authentication.

6.1.2 Authorisation

Once a user has been authenticated, the process of authorisation begins - this is understanding what permissions the user should have.

1. When a user has been authenticated, a session is established with the AAA server
2. The router requests authorisation for the requested services from the AAA server
3. The AAA server returns a PASS / FAIL for authorisation

6.1.3 Accounting

All actions within the network should be logged through an accounting mechanism - this ensures actions are recorded should they need to be investigated in the future.

1. When a user has been authenticated, the AAA accounting process generates a start message to begin the accounting process
2. When the user finishes, a stop message is recorded and the accounting process ends

6.2 Authentication

6.2.1 Authentication Factors

Authentication factors are factors which can be used to prove who you are. In an insecure system only one factor will be used, but in a secure system: two or more factors will be used.

- What You Know: An answer to a question that only you know, for example 'What is your password?'
- Where You Are: An IP address or Geolocation which your account is restricted to access from only, for example 'You may only login to your Microsoft account from the corporate IP range.'
- What You Are: A physical factor which only you possess, for example biometrics
- What You Have: A physical, or virtual, device which only you have, for example secure tokens or mobile devices with the Microsoft Authenticator App

6.2.2 Password Based Authentication

Passwords should be secret. Known only to you, and the hacking group which compromised the service you use it on. This is the sad reality of passwords; as found in 2012 over 75% of network intrusions exploited weak or stolen credentials, and on average 8 out of every 9 exploits involve password stealing and / or cracking¹.

There are numerous ways to crack passwords, whether this be human error such as:

- allowing shoulder surfing
- using the same password on multiple services

¹Verizon Data Breach Investigations Report

- being vulnerable to social engineering
- using a password which is adjacent to the place the password is being used at (such as company name, etc)

or technical, with issues such as:

- broken implementations
- bugs which expose passwords
- keyloggers or sniffers used
- dictionary attacks exploited on username and password input fields

The most we can do to secure our passwords is to hash or encrypt them in some way, but even this can be problematic if the hash is released as these can be cracked. There has been a significant amount of research conducted as to what passwords are being used, and from this databases of commonly used has been produced.

A key issue with password based authentication is default passwords on devices. For example routers commonly come with the credentials admin/admin.

Personal Identification Number (PINs) are just as bad as passwords. There are even less combinations so it is even more likely that the same PIN will be used more commonly.

This is all before we get to the issues with resetting passwords through forgotten password sequences. There are the common security questions (Mothers Maiden Name; First Car; First Pet; etc). But there's only so many answers to these. For example 'What was the make of your first car?' will commonly be answered by 'Ford' as they had a greater than 25% market share until the late 1990s. Information relating to these questions is also likely to be available from public social media profiles - LinkedIn is great at leaking your schools, universities, areas you lived, worked; Facebook is wonderful at leaking what you do in pastimes, hobbies, and friends names etc.

While saying all this, there are some things we can do to strengthen passwords:

- Transformed passwords
- Time stamps
- One Time Passwords
- Zero-knowledge techniques
- Digital Signatures
- Personal Tokens

But it is possible to take this too far, for the average users at least. For example going through two, three or four different authentication and security measures before doing something mundane like accessing emails. Users won't do all this, they'll avoid setting them up, or actively disable them - making their account less secure and more vulnerable to attacks.

6.2.3 Biometric Authentication

In contrast to the above Password Based Authentication shenanigans, *biometric authentication* sounds wonderful. There's nothing for users to remember (and therefore forget); they're often passive (i.e. not needing to type something or carry a device around); usually they can't be shared; and usually biometrics are unique (if measurements are taken sufficiently).

But there are issues with Biometrics:

- They're private, not secret. Consider a fingerprint - this gets left everywhere you touch

- Even random looking biometrics may not be sufficiently unique for authentication (consider birthdays)
- They're potentially forgeable (consider handwriting)
- Revocation of them is difficult or impossible (without cutting someone's eyes out or fingers off)

Poor quality biometrics also simply don't work at times. Face recognition (by a computer algorithm) experiences an error rate of up-to 20% given variations in lighting, viewpoint, and expressions. This is hugely frustrating for users if for one in every five times they try to unlock their phone, it doesn't work.

Fingerprints are the traditional method for identification. These use a 16-point match, which gives the probability for a false match of 1 in 10 billion. There were no successful challenges with this until 2000. However, fingerprint damage impairs recognition - such as a scar on the fingerprint of the user.

Alternatively to faces or fingers, it is possible to use irises to identify individuals. Irises are random when grown but stable throughout life. It is possible to generate a 256-byte iris code based on concentric rings between the pupil and the outside of the iris. The error rate is better than 1 in 1 million.

It is also possible to hand geometry, voice, ear shape, vein pattern and face temperature.

It is possible to obtain copies of biometrics using scientific techniques, or simply play-doh.

6.2.4 Authentication Alternatives

There are a number of alternative authentication methods which can be used instead of the traditional password-based or biometric-based authentication.

Graphical passwords are images-based authentication methods where the user clicks on screen in a particular pattern. This is especially vulnerable to shoulder surfing, however, as while hands can cover most of the keyboard to obfuscate which key is being typed - the movement of a mouse and pointer on screen is much more obvious.

Electronic Tattoos can also be used, where a small NFC-esque circuit is tattooed onto the user. This is vulnerable to sweat which may move or distort the circuit.

Chip filled pills (no not potato chip, electronic chips) can be swallowed which react with the stomach acid inside the users stomach to activate an 18-bit ECG-like signal inside your body.

Another alternative could be to use a SecurID token which is a small key-fob that generates a 6-digit Time-based One Time Passcode that can be used to login. Obviously apps like Ente Auth, Google Authenticator or even the dreaded Microsoft Authenticator exist to generate TOTP codes - but it's more annoying to users to have to lug a fob around with them. And that's our goal, right?

6.3 Distributed Authentication

Businesses have a problem: authentication. They have lots of users and lots of servers (or services) and users need authenticated access to these servers. The Naive solution to this might look like every server having a copy of every user's passwords. But this is insecure: if a threat actor can break into one server, they can compromise all users; and inefficient: to change a users password, the user must contract every server and ensure it's updated there.

We need a better solution than the naive solution above as that's pants. Our solution needs:

- to be secure against attacks by passive eavesdroppers and actively malicious users
- to be transparent: users shouldn't notice authentication taking place; and users should only be asked to enter their password rarely

- to be scalable so it is able to support a large number of users and servers

6.3.1 Kerberos

Kerberos was developed at MIT in the 1980s. It is a distributed authentication method which works as follows:

1. User contacts Key Distribution Centre (KDC) with their user identifier
2. KDC responds to user with an encrypted Ticket Granting Service (TGS) ticket
3. The user sends the TGS ticket to the TGS
4. The TGS returns an encrypted service ticket to the user
5. The user uses the Encrypted service ticket to access network services such as a file server, printer, etc

This two-step authentication process allows the users to prove their identity once to obtain a TGS ticket. They can then transparently use this TGS ticket to get tickets for any network service.

The TGS ticket contains data fields:

- User's name
- Server name
- Address of user's workstation (otherwise a user on another workstation can steal the ticket and use it to gain access to the server)
- Ticket lifetime
- A few other things (session key, etc)

A key threat with Kerberos is Ticket Hijacking - where malicious users may steal the service ticket of another user on the same workstation and try to use it. The network address verification of the malicious user does not help, as this can always be spoofed. Servers must verify that the user who is presenting the ticket is the same user to whom the ticket was issued.

Another key threat is that of not having a server to authenticate against. In this situation an attacker may misconfigure the network so that they receive the messages addressed to a legitimate server. It is possible for the attacker to capture private information from users and / or deny services. To circumvent this, the servers must prove their identities to users.

Kerberos Version 5 provides better user-server authentication. It generates a separate subkey for each user-server session instead of re-using the session key contained in the ticket. Authentication to servers is then done using subkeys not timestamp increments. V5 also includes authentication forwarding (delegation) where servers can access other servers on a user's behalf, ie the print server can access the email server to fetch an email. Realm hierarchies for inter-realm authentication are new as well as explicit integrity checking and standard CBC modes. V5 also now supports multiple encryption schemes, not just DES.

6.3.2 Multiple Administration Domains

An Administrative domain is a service provider holding a security repository permitting easy authentication and authorisation with clients using their credentials. They are a solution for managing many users with different security requirements.

The solution often takes the form of a hierarchical domain in a tree-shape.

X.500 is a series of standards for electronic directory services. The application uses Directory User Agent to access a Directory Access Point. All objects in the directory contain a Distinguished Name

(DN). X.511 defines standard directory operations including read, compare, list, search and modification requests. This is an incredibly complex series of standards and suite of protocols.

The *Lightweight Directory Access Protocol* (LDAP) is a simplified version of X.500. It is widely used for internet services and is an application level protocol which uses TCP. LDAP lookups and updates can use strings instead of OSI encoding and uses master servers and replica servers for performance improvements. There are numerous example implementations including Active Directory, Novell Directory Services, Linux / Unix, and iPlanet Directory Services (Netscape). Typical use-cases for LDAP include user profile management, access privilege management, and network resource management.

Page 7

Lecture - IPsec, VPN & MPLS

📅 2026-03-24

🕒 14:00

👤 Shikun

7.1 Internet Protocol: A Recap

The *Internet Protocol* (IP) is implemented in every end user device and in routers. It is an unreliable protocol as IP datagrams may be lost and may arrive out of order. The *Transmission Control Protocol* (TCP) takes care of the problems. There are two versions of IP: IPv4 and IPv6. Both versions map to a variant of the IP address - which is an identifier used to identify a network connected device during data transmission.

IP, on it's own, is insecure. The content of an IP datagram is not encrypted, therefore confidentiality is not provided; this makes it easy to 'sniff' the payload. There are IP sniffers available on the Internet. IP addresses may spoofed which can break authentication based on IP addresses.

7.2 IPsec

IPsec, or to use it's full name *Internet Protocol Security*, is a suite of protocols designed to secure internet communication by authenticating and encrypting each IP packet in a data stream. This provides authentication and confidentiality, which we know make up two thirds of the CIA triangle - so must be a good thing. IPsec also has key management features.

IPsec is not bound to any specific encryption algorithms, authentication algorithms, keying technology or security algorithms. Rather it is a framework to ensure flexible yet thorough standards for security. It protects and authenticates IP packets between source and destination. IPsec can protect nearly all traffic from Layer 4 through to Layer 7 of the OSI model.

At it's core - IPsec has five main components:

- IPsec Protocol
- Confidentiality using encryption
- Integrity using hashing algorithms
- Authentication using Internet Key Exchange (IKE)
- Secure key exchange using the Diffie-Hellman (DH) algorithm

IPsec supports:

- Access Control Authentication
- Data Encryption
- Data Integrity
- Nonrepudiation

IPsec works at layer 3 of the OSI model (network layer) and can encrypt an entire TCP/IP packet. It was originally for use with IPv6 although supports IPv4. IPsec can provide authentication before the data is transmitted.

7.2.1 IPsec Protocol

The IPsec Protocol is responsible for sending data packets securely. These packets a format similar to that of an IP packet so consist of a header, payload, and trailer:

- Header: a preceding section that contains instructional information for routing the data packet to the correct destination
- Payload: the actual information contained within a data packet
- Trailer: additional data appended to the tail of the payload to indicate the end of the data packet

There are two main protocols used: Authentication Header (AH) and Encapsulating Security Payload (ESP). The choice of which protocol to use establishes which other building blocks are available to flesh out the framework.

The *Authentication Header* (AH) IPsec Protocol achieves authenticity by applying a keyed one-way hash function to the packet to create a hash or message digest. The hash is combined with the text and transmitted in plain sight. On the receiving end - the hash is recomputed and the authenticity of the original message is based on if the received and recomputed hashes match.

The *Encapsulating Security Payload* (ESP) IPsec protocol provides confidentiality by encrypting the payload, and can also provide integrity and authentication using either MD5 or SHA. This works through encapsulating the original IP packet by authentication or encryption headers and trailers. When both authentication and encryption are selected - encryption is performed first.

7.2.2 IPsec Uses

IPsec is commonly seen used in Virtual Private Networks (VPNs) which allow for interconnected LANs over the insecure internet in a router-to-router paradigm. Alternatively IPsec VPNs can be seen in a secure remote access paradigm where an individual, and therefore a single device, is connected to the corporate network.

7.2.3 IPsec Usage Modes

There are two usage modes that IPsec can operate in.

7.2.3.1 Transport Mode

Security is provided only for the transport layer and above; it protects the payload but leaves the original IP address in plaintext. ESP transport mode is used between hosts where an encrypted TCP session forms.

For example, a packet may consist of: the IP header with the real destination shown; the IPsec header; and then the TCP/UDP header & data. Where only the final section (TCP/UDP header & data) is encrypted.

7.2.3.2 Tunnel Mode

Security is provided for the complete original IP packet. This is achieved through encrypting the original IP packet then encapsulating this in another IP packet (IP-in-IP encryption). ESP tunnel mode is used in remote access and site-to-site implementations where the secure tunnel is formed between *Security Gateways*.

For example, a packet may consist of: IP Header (gateway address); IPsec header; IP header (real destination); and then TCP/UDP header & data. Where the IP header as well as TCP/UDP header & data sections are both encrypted.

7.2.4 Security Association

Security Association (SA) is a one-way sender-recipient relationship. It determines how packets are processed; including details such as cryptographic algorithms, keys, IVs, lifetimes, sequence numbers, mode (transport or tunnel). Each SA is uniquely identified by a Security Parameter Index (SPI); and each IPSec keeps a database of SAs. A SPI is sent with packets which tells the recipient what SA to use.

SA defines:

- The protocol used (AH or ESP)
- Mode (transport or tunnel)
- Encryption or Hashing algorithm to be used
- Negotiated keys and key lifetimes
- Lifetime of this SA
- And more non-detailed information in the slides

7.2.5 Authentication Header Implementation

The Authentication Header (AH) provides sender authentication and therefore integrity for packet contents and IP header. Before an AH can be used - the sender and receiver must share a secret key.

In transport mode - an additional AH header is added between the original IP header and the TCP header, recalling that these won't be encrypted as only the data gets encrypted.

In tunnel mode - an AH header is prepended with the new IP header prepended onto that; so that everything from the original IP header to the end of the original trailer components can be encrypted.

7.2.6 Internet Key Exchange

The goal of the *Internet Key Exchange* (IKE) is to establish security association for AH and ESP. If IKE is broken then AH and ESP provide no protection.

The IKE is used as follows when negotiating an IPSec Tunnel VPN connection:

1. Host A sends interesting traffic to Host B.
2. R1 and R2 negotiate and IKE Phase 1 session
 - (a) Negotiate ISAKMP policy (relating to Encryption, Authentication, etc for that connection)
 - (b) DH Key Exchange
 - (c) Verify peer identity
3. R1 and R2 negotiate an IKE phase 2 session
 - (a) Negotiate IPSec policy
4. Information is exchanged via IPSec tunnel
5. The IPSec tunnel is terminated

7.3 SSL/TLS

SSL or TLS are above the TCP socket, so they form part of the Application Layer. This is the inverse of IPSec which sits below the TCP layer.

Transport Layer Security (TLS) is used for emails. *Secure Socket Layer* (SSL) is used for a number of different applications, including: HTTPS (Secure Web Access), SSH (Secure Shell), SCP (Secure Copy), and SFTP (Secure File Transfer).

7.3.1 Certificates

There is a need for the browsers on users devices who are attempting to access resources to be able to obtain the certificate of the resource they are trying to access. This will likely come from a certificate authority.

The process of signing a new certificate works something like the following:

1. The applicant compiles the identifying information and a public key into a *Certificate Signing Request* (CSR).
2. The CSR is sent to the Certificate Authority.
3. The Certificate Authority validates that the applicant is who the applicant says they are
4. The Certificate Authority then generates the signed certificate and sends it to the applicant, as part of this process - the CA includes it's own private key to verify the originality of the certificate.

The CA structure is hierarchical. There are approximately 60 top level CAs, with 1200 intermediate CAs actually issuing the certificates.

When a browser first contacts a server with a 'client-hello' message the browser responds with the 'server-hello' and 'server-cert'. This leads into a key exchange, where the server sends it's keys to the client and the client responds with it's keys; this now creates trust between the browser and client so they can communicate using encrypted HTTPS traffic.

7.4 Virtual Private Networks

A *Virtual Private Network* (VPN) is an encrypted tunnel between two (or more) devices. This may be seen in the paradigm of a single end user remotely connecting into the office network while they telework, or between different sites; in either case the connection uses the public internet infrastructure and uses the encrypted VPN tunnel to secure the connection.

A *Remote Access VPN* is typically enabled by the user when required. They can be created using either IPsec or SSL. The remote user must initiate a remote access VPN connection - which could take place in a clientless and client-based connection.

A *site-to-site* VPN is where the VPN gateway encapsulates and encrypts outbound traffic. This traffic is then sent through a VPN tunnel over the internet to a VPN gateway at the target site. Upon receipt, the receiving VPN gateway strips the headers, decrypts the content and relays the packet towards the target host inside its private network. Site-to-site VPNs are typically created and secured using IPsec.

7.5 MPLS

Multiprotocol Label Switching (MPLS) is a networking technology that directs data using labels rather than long network addresses, enabling faster, reliable, and prioritized traffic flow. This is currently only defined for IP. A MPLS path can be considered as a tunnel which goes from a MPLS ingress point to an egress point.

7.5.1 Motivation

As we've already seen today and in the years preceding this; IP was the first defined and used networking protocol. That's made it the de-facto protocol for global internet connectivity. However, it has some disadvantages. IP is a connectionless protocol which means each router has to make independent forwarding decisions based on the IP address; there's a large IP header; routing is done in the network layer which is slower than switching; and it is usually designed to obtain the shortest path regardless of how good those paths actually are.

An alternative protocol used is the *Asynchronous Transfer Mode* (ATM) which is connection oriented, and therefore maintains higher QoS; has fast packet switching with fixed length packets (called cells); and integrates different types of traffic (voice, data and video). However there are disadvantages: it's complex, expensive and not widely adopted.

So this brings us to the idea of MPLS: combine the forwarding algorithm used in ATM with IP.

7.5.2 Basics

MPLS sits between layer 2 and layer 3 of the OSI model; this means it sits between IP (L3) and ATM (L2). MPLS includes mechanisms to manage traffic flows in a number of granularities (flow management). It maps IP addresses to fixed length labels and has interfaces to existing routing protocols (such as RSVP or OSPF). MPLS supports ATM, Frame-Relay and Ethernet.

7.5.3 Labels

The MPLS shim slots in between the Link Layer header and the Network layer header in the packet as it travels down the OSI model; it takes a generic format:

- 20 bits for the label itself
- 3 experimental bits, often used for class of service
- 1 bottom of stack (BS) bit, which is set if no label follows
- 8 Time to live (TTL) bits used in the same way IP uses TTL bits

When the BS bit is set to 1, the current label is on the bottom of the stack. This is important as multiple labels can be encoded into the same packet to form a label stack.

MPLS does not specify a single method for label distribution. The BGP protocol has been enhanced to piggyback the label information within the contents of the protocol; similarly the RSVP protocol has been extended to support piggybacked exchange of labels.

IETF has defined a new protocol known as the label distribution protocol (LDP) for explicit signalling and management. Extensions to the base LDP protocol have also been defined to support explicit routing based on QoS requirements.

A *Label Edge Router* (LER) (or Edge label Switch Router) resides at the edge of an MPLS network and assigns and removes the labels from packets. LERs support multiple ports connected to dissimilar networks, such as Frame Relay, ATM and Ethernet.

A *Label Switching Router* (LSR) is a high speed router in the core of an MPLS network. ATM switches can be used as LSRs without changing their hardware.

A *Forward Equivalence Class* (FEC) is a representation of a group of packets that share the same requirements for their transport. The assignment of a particular packet to a particular FEC is done just once, when the packet enters the network.

A *Label Switched Path* (LSP) is a path established before the data transmission starts. A path is a representation of a FEC. MPLS provides two options to setup an LSP. Option one is hop-by-hop

routing where each LSR independently selects the next hop for a given FEC; LSRs may support any available routing protocols (OSPF, ATM, etc). Option two is explicit routing which is similar to source routing where the ingress LSR specifies the list of nodes through which the packet traverses.

Traffic Engineering is inherently provided using explicitly routed paths in MPLS. The LSPs are created independently, specifying different paths that are based on user-defined policies; however this may require extensive operator intervention. RSVP-TE and CR-LDP are two possible approaches to supply dynamic traffic engineering and QoS in MPLS.

RSVP-TE requests bandwidth and traffic conditions on a defined path. This has the drawback of requiring regular refreshes and not being scalable. *CR-LDP* takes into account parameters such as link characteristics (bandwidth, delay, etc), hop count and QoS. It is entirely possible that a longer (by means of cost) but less loaded path is selected; however this does add complexities to routing calculations.

7.5.4 Operation

The following steps must be taken for a data packet to travel through a MPLS domain:

1. label creation and distribution
2. table creation at each router
3. label-switched path creation
4. label insertion / table lookup
5. packet forwarding

7.5.4.1 Step 1: Label Creation and Label Distribution

Before any traffic begins moving on the network, the routers make the decision to bind a label to a specific FEC and build their tables. In LDP, downstream routers initiate the distribution of labels and the label / FEC binding. Additionally, traffic related characteristics and MPLS capabilities are negotiated using LDP. A reliable and ordered transport protocol should be used for the signalling protocol.

7.5.4.2 Step 2: Table Creation

On receipt of label bindings, each LSR creates entries in the *Label Information Base* (LIB). The contents of the table will specify the mapping between a label and a FEC. This mapping maps between the input port and the input label table to the output port and output label table. The entries are updated whenever renegotiation of the label binding occurs.

7.5.4.3 Step 3: Label Switched Path Creation

The LSPs are created in the reverse direction to the creation of the entries in the LIBs.

7.5.4.4 Step 4: Label Insertion / Table Lookup

The first router uses the LIB table to find the next hop and request a label for the specific FEC. Subsequent routers just use the label to find the next hop. Once the packet reaches the egress LSR, the label is removed and the packet supplied to its destination.

7.5.4.5 Step 5: Packet Forwarding

The first router may not have any labels for a packet as it is the first occurrence of the request. In an IP network, it will find the longest address match to find the next hop; in this case that's a hop towards a LSR. The request propagates through the network with each intermediary router receiving a label

from its downstream router. If traffic engineering is required, CR-LDP will be used in determining the actual path setup to ensure the QoS / CoS requirements are complied with. Eventually the edge router handling the packet will receive it's label and this will be forwarded to the first LSR in sequence. Each subsequent LSR will examine the label in the received packet and replace it with the outgoing label and forward it. When the packet reaches the LER on the other edge of the network, it will remove the label because the packet is departing from the MPLS domain and deliver it to the destination.

7.5.5 Advantages and Disadvantages

MPLS improves packet forwarding performance in the network. It supports QoS and CoS for service differentiation. MPLS supports networks scalability and integrates IP and ATM in the network. It builds interoperable networks.

However, an additional layer is added and the router has to understand MPLS.

7.5.6 MPLS VPN

There are four components to a MPLS VPN:

- CE Router: Customer Edge routers
- PE Router: Provider Edge routers
- P Router: Provider Router
- ASBR Router: AS border router

The CE routers connect to the PE routers at the borders, with the CE routers providing the VPN interface to the customer. Inside the MPLS network, the PE routers connect to P routers which transmit the packets through ASBR routers (if needed to cross ASs) to other P routers.

Page 8

Lecture - Auditing

📅 2026-04-21

🕒 14:00

👤 Shikun

NB. This is an abridged version of the lecture. Materials were only published for some of the content covered, it is assumed the content without published materials will not be included in the final exam.

8.1 Introduction

Audit is derived from the Latin word ‘audire’ which means to hear authenticity of accounts is assured with the help of independent review.

This is a concept which originated in the world of finances, where accounts would be scrutinised to ensure their authenticity, accuracy and legality. This concept has leached into cyber security as reporting on activities is also a vital activity. The concept of auditing has also percolated into other areas of society, for example a University module having an external examiner to validate the work of the internal module team.

Auditing provides an intelligent and critical examination and exhibits an accurate and fair view of the state of affairs of concern. Within cyber security, an audit is performed to ascertain the validity and reliability of Security Policy and its enforcements. This is used to detect and prevent error & fraud, and to check the effectiveness of security systems.

The systematic evaluation of IT infrastructure involved in auditing can detect high-risk activities, threats and vulnerabilities. This ensures that security measures are either in place, or identifies gaps, to protect against cyber attacks.

8.2 Types of Audits

There are a number of different types of audits, used in different scenarios.

8.2.1 Process Audit

A *process audit* verifies that processes are working within established limits. They evaluate the an operator or method against the written security policy to measure conformance to said policy and to record the effectiveness of a security system.

A process audit can also examine the resources, the environment, the method followed and the measurements collected to determine process performance. This information is then used to check the adequacy and effectiveness of the process controls established by procedures and instructions, flowcharts as well as training and process specification.

For example an audit may examine the process followed when an employee laterally moves within a company, to ensure access to systems they no longer require access to is revoked.

8.2.2 Product Audit

A *product audit* is an examination of a particular security product or service. It may look at hardware, software or servers. Product audits seek to evaluate whether said product or service conforms to security requirements.

For example, a product audit may explore a piece of software to seek out vulnerabilities which expose sensitive data in an unauthenticated way or allow an adversary to access components of the system they should not have access to.

8.2.3 System Audit

A *system audit* is an audit conducted specifically on a management system. They manifest as a documented activity performed to verify, by examination and evaluation of objective evidence, that applicable elements of the system are appropriate and effective, and have been developed, documented, and implemented in accordance and conjunction with specified requirements. This may be seen as an audit to verify compliance with ISO 27001 or SOC 2.

For example, taking a list of users and permissions in the ERP and identifying who has access to approve spend (on paperclips) that they shouldn't.

8.3 Auditing Process

There are three key sections to the auditing process:

1. Reviewing Security Policies - This ensures the policies are written in a way such that they align with the industry standards, or good practice guidelines.
2. Evaluating Security Practices - Checking if the defined security protocols are being followed.
3. Assessing Risk Management - Identifying potential threats and their impact.

8.4 Logging

Much of modern auditing is automated - for example notifications sent to all Administrators for a system when a significant change is made, or when a suspicious login is detected. Even if no alerts are sent, activities conducted by users and administrators will commonly be logged. *Logging* is the idea of recording system events and interactions. Having this data available is a useful concept for auditing where analysis of log records form a type of logging.

So this automated logging and notification system, as part of an auditing system, would have three components:

- Logger - to capture the data as it happens
- Analyser - to review the log entries and flag anomalies / high risk activities
- Notifier - to send notification to the relevant people(s).

8.4.1 Logging on Single Workstations

In Linux & Unix derived systems system logs are captured in the `/var/log/` directory using daemons such as `klogd` and `syslogd`. In Windows logs are confined to the Event Viewer where they can be reviewed with great pain and suffering. However in more complex setups, beyond a single workstation, *Syslog* can be used as a central logging tooling.

8.4.2 Syslog

Syslog is used to collect log messages generated by a device or an application and report to a centralised *syslog server*. This server may collect logs from different network devices (routers, switches, servers, firewalls, etc) and archives them in a secure location where they can be processed. The UI for the syslog server will provide searching and sorting capabilities on the logs for ease of access.

Syslog messages are assigned as severity level as can be seen below.

Code	Severity	Description
0	Emergencies	System inoperable
1	Alerts	An immediate intervention is required
2	Critical	Critical System Error
4	Warnings	Warning (an error may occur if no action is taken)
5	Notifications	Normal event that must be reported
6	Informative	For information
7	Debug	Debugging message

Table 8.1: Syslog severity levels

An example Syslog message is shown below, conveying that the state of S0/0/1 has changed to down.

39345: May 22 13:56:35.811: %LINEPROTO-5-UPDOWN: Line protocol on Interface Serial0/0/1, changed state to down

8.5 Simple Network Management Protocol

Simple Network Management Protocol (SNMP) is used to monitor the performance of the network and know the overall state of devices (active, inactive, partially operational, network gridlocked, etc); to detect problems on the network equipment and manage exceptional events (such as loss of a network link, equipment suddenly ceasing to function, etc); and to configure equipment.

SNMP works on the application layer and uses UDP on port 162 to communicate.

SNMP provides an integrated collection of tools for network monitoring and control, with a single operator interface. There is a minimal amount of separate equipment as the software and network communications capability is built into the existing equipment.

The key elements of SNMP are listed below:

- Management station
- Management agent
- Management information base
- Network management protocol (get, set and notify)

The *SNMP manager* is the host that executes the SNMP management software. Commonly this is a computer that is used to monitor the network. The *SNMP agent* is the software running on the network device (router, switch, etc) that allows it to be monitored. The *management information base* (MIB) is a set of object collections managed by the SNMP agent; each collection contains a certain number of variables that may be consulted or modified by the SNMP manager.

There are multiple versions of SNMP - SNMPv1, SNMPv2 and SNMPv3. SNMPv1 is 'connectionless' as it uses UDP; while SNMPv2 is 'connection-oriented' as it uses TCP.

SNMPv1 has a community facility which manages the relationship between a SNMP agent and SNMP manager. There are three aspects of agent control:

- authentication service

- access policy
- proxy service

SNMPv3 defines a security capability to be used in conjunction with SNMPv1 or v2. This is provided through the *User-based Security Model* (USM) which provides authentication, integrity and encryption for network messages. USM is designed to secure against modification of information, masquerade attacks, message stream notification and disclosure. However it is not intended to secure against DoS attacks or traffic analysis.

SNMP data can be secured further using *View-based Access Control Model* (VACM) which has two characteristics we care about. VACM determines whether access to a managed object should be allowed; and also makes use of a MIB that defines the access control policy for the agent and makes it possible for remote configuration to be used.

FREELY GIVEN, HIGHLY QUESTIONABLE

These notes are a byproduct of my learning process - mistakes, bad jokes and snark included. If you take an error of mine as gospel and ruin your perfect 1st, that is a *you* problem boo. I am a student, not a prophet, use a textbook if you want certainty.

Yes, they have been typeset in $\text{\LaTeX}$; I'd rather typeset in stone with a blunt chisel than use Word Online for another minute. If the formatting looks obsessive, it's because it was either this or a breakdown. You can find the source on my [GitHub](#).

They're licensed under CC-BY-4.0. So do what you will with them; just attribute them to me. Plagiarism is a bad look, and I've got just enough snark left for you bestie.

Thomas Boxall is a Computer Science Student studying at the University of Portsmouth, UK. In all honesty, he should probably be revising or doing some work towards his dissertation, not fondling the template of his notes again. You can find Thomas online at thomasboxall.net